

# Seguridad en Comercio Electrónico

## Desarrollo de Software IX

UNIVERSIDAD

Universidad Tecnológica de Panamá

FACULTAD

Ingeniería de Sistemas Computacionales

TEMA

Protección Integral de Plataformas E-commerce

### CONTENIDO

01 Panorama de Amenazas 2024

03 Tríada CIA

05 Encriptación vs Hashing

07 OWASP A01 – Broken Access Control

09 OWASP A03 – Injection

11 Account Takeover (ATO)

13 Defense in Depth – Perímetro y Red

15 Defense in Depth – Identidad

02 Vulnerabilidad, Amenaza y Riesgo

04 Autenticación vs Autorización

06 Principios Fundamentales

08 OWASP A02 – Cryptographic Failures

10 Card Testing / Carding

12 Digital Skimming (Magecart)

14 Defense in Depth – Aplicación y Datos

16 Resumen y Métricas Clave

01

## 1 Panorama de Amenazas en E-Commerce 2024

95%

Sitios web con alguna vulnerabilidad

\$41B

Pérdidas por fraude online (2023)

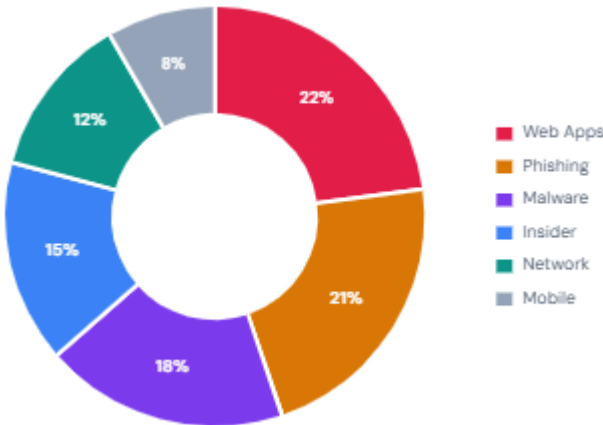
206d

Promedio para detectar una brecha

\$4.45M

Costo promedio violación de datos

### Vectores de Ataque Principales



+38% en ataques durante Black Friday · 73% de sitios e-commerce tienen vulnerabilidades críticas

### Industrias Más Atacadas

| Industria           | % Ataques | Tipo Principal      |
|---------------------|-----------|---------------------|
| E-commerce / Retail | 23.1%     | Web Apps            |
| Fintech             | 19.7%     | Credential Stuffing |
| Servicios           | 15.2%     | Phishing            |
| Tecnología          | 12.8%     | Supply Chain        |
| Salud               | 11.4%     | Ransomware          |

### Tendencias Emergentes 2024

- ▶ **AI-Powered Attacks:** Deepfakes y phishing automatizado con LLMs
- ▶ **Supply Chain:** Ataques a dependencias y bibliotecas (npm, PyPI)
- ▶ **API Security:** 60% más ataques a APIs que a aplicaciones web
- ▶ **Mobile Commerce:** +140% en ataques a aplicaciones móviles

02

2 Vulnerabilidad vs Amenaza vs Riesgo



### Vulnerabilidad

Debilidad en un sistema que puede ser explotada.

Ej: SQL Injection en formulario de login sin prepared statements

```
SELECT * FROM users
WHERE user = '$input'
```



### Amenaza

Cualquier agente que pueda explotar una vulnerabilidad.

**Actores:** Cibercriminal, Bot automatizado, Insider malicioso

Ej: Script masivo buscando formularios vulnerables a SQLi



### Riesgo

Probabilidad de que una amenaza explote una vulnerabilidad.

**Fórmula:**

**Riesgo = Amenaza × Vulnerabilidad × Impacto**

**Ejemplo E-commerce:** Checkout sin validación → Script automatizado SQLi → 70% prob. de compromiso de 50K tarjetas → \$2.5M multas PCI DSS

03

3 Tríada CIA — Pilares de la Seguridad



### CONFIDENCIALIDAD

Información accesible solo a usuarios autorizados

- Datos de tarjetas encriptados
- Información personal de clientes
- Credenciales de acceso seguras
- Datos financieros internos

Encriptación · Control de acceso



### INTEGRIDAD

Información no alterada de manera no autorizada

- Precios de productos sin manipular
- Órdenes de compra exactas
- Logs de auditoría inmutables
- Código de aplicación verificado

Hashing · Firmas digitales



### DISPONIBILIDAD

Sistemas accesibles cuando se necesiten

- Sitio web funcionando 24/7
- Procesamiento de pagos activo
- Base de datos accesible
- APIs respondiendo correctamente

Redundancia · Backups · Anti-DDoS

**Impacto económico de violaciones CIA:** Confidencialidad → Multas PCI DSS \$5K–\$100K/mes · Integridad → Manipulación de precios = pérdidas directas · Disponibilidad → 1h downtime = \$100K–\$300K en ventas perdidas

04

## 4 Autenticación vs Autorización

 **AUTENTICACIÓN — "¿Quién eres?"**

Verificar la identidad de un usuario antes de permitir acceso.

**SABES**  
Contraseña,  
PIN, Pregunta  
de seguridad

**TIENES**  
Teléfono (SMS),  
Token  
hardware, TOTP

**ERES**  
Huella dactilar,  
Facial, Iris

 **AUTORIZACIÓN — "¿Qué puedes hacer?"**

Determinar qué puede hacer un usuario ya autenticado.

| Rol      | Permisos                                               |
|----------|--------------------------------------------------------|
| Cliente  | Ver sus pedidos, actualizar perfil, comprar            |
| Vendedor | Ver sus productos, actualizar inventario, devoluciones |
| Admin    | Gestionar todos los pedidos, productos, reportes       |

05

## 5 Encriptación vs Hashing

 **ENCRYPTACIÓN — Proceso Reversible**

- Requiere clave para descifrar
- Datos recuperables
- AES-256 / RSA / TLS 1.3
- Tarjetas de crédito en DB
- Info personal sensible
- Comunicación HTTPS

Texto: "4532-1234-5678-9012"

→ AES-256 → "A7B9C1D3E5F7..."

← con clave → "4532-1234-5678-9012"

**# HASHING — Función de Una Vía**

- Sin clave, irreversible
- Longitud fija de salida
- bcrypt / SHA-256 / Argon2
- Almacenar contraseñas
- Verificar integridad
- Tokens de sesión

Password: "MiPassword123"

→ bcrypt(12 rounds) →

"\$2b\$12\$LQv3c1..." (irreversible)

06

## 6 Principios Fundamentales de Seguridad

**Defense in Depth**

Múltiples capas independientes

- Firewall + WAF + IDS
- Auth + Authz + Auditoría
- Si una capa falla, otras protegen

**Least Privilege**

Acceso mínimo necesario

- Usuarios: Solo sus datos
- Apps: Permisos específicos
- Servicios: Recursos mínimos

**Fail Secure**

Fallo en modo seguro

- Error DB → Denegar acceso
- Falla auth → Logout
- Red caída → Offline seguro

**Security by Design**

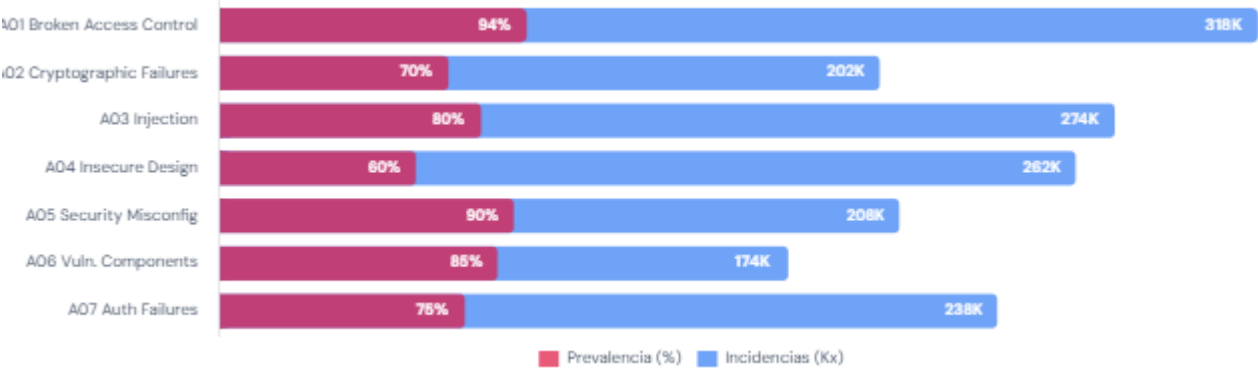
Seguridad desde el diseño

- Threat modeling desde inicio
- Arquitectura con seg. integrada
- No como "add-on" posterior

07-09

7 OWASP Top 10 — Vulnerabilidades Críticas en E-Commerce

Comparativa de Riesgo y Prevalencia



A01  
Broken  
Access  
Control

94% de apps tienen algún tipo de BAC. Ver pedidos ajenos cambiando IDs en URL, acceso a panel admin sin auth, modificar precios en HTTP.

```
// ✅ Verificar propiedad del recurso
if (!userOwnsOrder(userId, orderId))
  return
res.status(403).json({error: 'Forbidden'})
```

A03  
Injection

SQL, NoSQL, Command, LDAP Injection. Inserción de código malicioso a través de inputs no sanitizados. Control total del servidor.

```
// ✅ Prepared statements
const [rows] = await db.execute(
  'SELECT * FROM users WHERE email=?',
  [email])
```

A02  
Cryptographic  
Failures

Contraseñas en texto plano, hash MD5, HTTP sin TLS, datos sensibles sin encriptar. Multas PCI DSS: \$5K-\$100K/mes.

```
// ✅ Hash seguro de contraseña
const hash = await bcrypt.hash(pwd, 12)
// ✅ Encriptación AES-256-GCM para tarjetas
```

A04-A10  
Otros  
Críticos

A04 Insecure Design · A05 Security Misconfiguration · A06 Vulnerable Components · A07 Auth Failures · A08 Integrity Failures · A09 Logging Failures · A10 SSRF

Testing para Injection: Manual: ' OR 1=1 -- · Automatizado: SQLMap, OWASP ZAP, Burp Suite · Code Review: Buscar concatenación de strings en queries

10 Card Testing / Carding

¿Qué es Card Testing?

Técnica automatizada donde cibercriminales prueban la validez de números de tarjetas robadas usando bots para realizar transacciones pequeñas (\$1-\$5 USD) en sitios e-commerce.

Anatomía del Ataque

1

**Obtención de datos**  
Dark web, data breaches, skimming, phishing

2

**Preparación**  
Bots (SentryMBA, STORM), proxy chains, user agents variables

3

**Ejecución**  
100-1000 micro-transacciones/min, rotación de IPs

4

**Monetización**  
\$1-3 tarjeta básica · \$10-50 premium · \$100+ "fullz"

Impacto Financiero

| Concepto             | Costo                 |
|----------------------|-----------------------|
| Chargeback fees      | \$15-25 / transacción |
| Processing fees      | \$0.30-0.50 / intento |
| Daño reputacional    | \$50K-100K anuales    |
| Investigación fraude | \$25-50 / caso        |

Técnicas de Mitigación

- ▶ **Rate limiting:** Máx. 3 intentos de pago / 15 min por IP
- ▶ **CAPTCHA inteligente:** reCAPTCHA v3 si risk score > 0.7
- ▶ **3D Secure 2.0:** Autenticación adicional por el emisor
- ▶ **Device fingerprinting:** User-agent, timezone, canvas hash
- ▶ **IP reputation:** Bloquear proxies, Tor, IPs con riskScore > 80
- ▶ **Behavioral analytics:** checkoutTime < 30s, amount < \$10, geoAnomaly

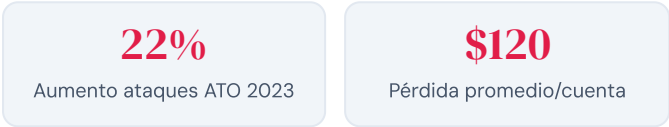
**Estadísticas alarmantes:** \$28 billones en pérdidas globales (2023) · 65% de sitios e-commerce sufren card testing mensualmente · 15-20% de tarjetas probadas resultan válidas · Picos: Black Friday, Cyber Monday, madrugadas

11

11 Account Takeover (ATO)

Métodos de Ataque

- ▶ **Credential Stuffing:** Usar credenciales de otros breaches (80% usuarios reutilizan passwords)
- ▶ **Password Spraying:** Contraseñas comunes contra muchas cuentas
- ▶ **Session Hijacking:** Robar tokens de sesión JWT/Cookie
- ▶ **SIM Swapping:** Bypass de 2FA por SMS
- ▶ **Phishing:** Páginas falsas para capturar credenciales
- ▶ **Malware:** Keyloggers e info-stealers



Indicadores de ATO

| Categoría      | Señales                                                       |
|----------------|---------------------------------------------------------------|
| Geográfico     | Login desde país diferente, múltiples países en 1 hora        |
| Temporal       | Fuera del horario habitual, inactividad prolongada + burst    |
| Comportamiento | Cambio dirección envío, nuevos métodos de pago, uso de puntos |
| Dispositivo    | Dispositivo desconocido, VPN/proxy, múltiples fallos + éxito  |

**Impacto:** \$50–500 por cuenta · 67% de clientes no vuelven tras ATO · Costos de investigación \$25–75/incidente

12

12 Digital Skimming — Magecart

Inyección de JavaScript malicioso en páginas de checkout que captura datos de tarjetas **en tiempo real**, sin interferir con la transacción normal. Difícil de detectar

Víctimas notables

- ▶ **British Airways (2018)** — 380K tarjetas comprometidas
- ▶ **Ticketmaster (2018)** — 40K tarjetas, activo meses
- ▶ **Newegg (2018)** — 1 mes activo sin detección

Contramedidas

- ▶ **Content Security Policy (CSP):** Controlar scripts permitidos
- ▶ **Subresource Integrity (SRI):** Verificar hash de scripts externos
- ▶ **Runtime Script Monitoring:** MutationObserver en DOM
- ▶ **File integrity monitoring:** Detectar cambios en JS/HTML
- ▶ **Auditorías periódicas:** Revisar todos los third-party scripts

13

13

# Defense in Depth — Capas de Protección

## Efectividad por Capa de Seguridad



### Capa 1: Perímetro y Red

**Web Application Firewall (WAF)**

- ▶ Bloqueo de SQL Injection y XSS en el borde
- ▶ Rate limiting avanzado por IP/usuario
- ▶ Geoblocking de países de alto riesgo
- ▶ Detección de firma de ataques conocidos

**DDoS Protection + IDS/IPS**

| Tipo Ataque | Volumen     | Duración  |
|-------------|-------------|-----------|
| UDP Flood   | 10–100 Gbps | 5–30 min  |
| SYN Flood   | 1–50 Mpps   | 10–60 min |
| HTTP Flood  | 10K–1M rps  | 1–6 horas |

### Capa 2: Aplicación

**SAST / DAST / IAST / RASP**

| Tipo | Cuándo                      | Herramientas       |
|------|-----------------------------|--------------------|
| SAST | Pre-build (código estático) | SonarQube, Semgrep |
| DAST | Post-deploy (app corriendo) | OWASP ZAP, Burp    |
| IAST | Durante tests (runtime)     | Contrast Security  |
| RASP | Producción (tiempo real)    | Sqreen, Contrast   |

### Capa 3: Datos

**En Reposo**  
AES-256-GCM,  
TDE,  
bcrypt/Argon2

**En Tránsito**  
TLS 1.3, HSTS,  
mTLS,  
VPN/IPSec

**En Uso**  
Intel SGX,  
Memory guards,  
Secure enclaves



15

15 **Defense in Depth — Capa 4: Identidad (IAM)**

Gestión de Identidad y Acceso

- ▶ **SSO / OAuth 2.0 / OIDC:** Google, Azure AD, Auth0 para autenticación federada
- ▶ **MFA obligatorio:** Para cuentas con métodos de pago almacenados
- ▶ **Anomaly detection:** ML para detectar logins anómalos por geo, tiempo, dispositivo
- ▶ **Step-up auth:** Requerir 2FA adicional para acciones sensibles (cambio de email, nuevo pago)
- ▶ **Breach monitoring:** HavelBeenPwned API para detectar contraseñas comprometidas



**Privileged Access Management (PAM)**

- ▶ **Just-in-time access:** Acceso elevado máx. 4h con flujo de aprobación
- ▶ **Session recording:** Grabación de sesiones privilegiadas
- ▶ **Zero Trust:** Verificar usuario + dispositivo + red + permisos en cada request

Identity Risk Scoring

| Factor                           | Puntos de Riesgo |
|----------------------------------|------------------|
| País diferente al habitual       | +30 pts          |
| Dispositivo desconocido          | +25 pts          |
| Múltiples intentos fallidos (>3) | +20 pts          |
| Horario fuera de lo usual        | +15 pts          |
| Score > 80 → Bloquear            | Acción           |
| Score 50–80 → Step-up 2FA        | Acción           |
| Score 30–50 → CAPTCHA            | Acción           |

**Identity Governance Metrics:** % usuarios con MFA habilitado · Cuentas inactivas >90 días · Access reviews completadas · Tiempo promedio de acceso privilegiado

16

16 **Resumen — Métricas Clave de Seguridad E-Commerce**

Checklist de Implementación

- ✓ Todas las contraseñas con bcrypt / Argon2 (saltRounds ≥ 12)
- ✓ HTTPS en toda la aplicación (HSTS habilitado)
- ✓ Datos sensibles encriptados en base de datos (AES-256)
- ✓ Rate limiting en login y checkout (máx. 3–5 intentos)
- ✓ MFA obligatorio para cuentas con métodos de pago
- ✓ WAF configurado con reglas anti-SQLi y XSS
- ✓ Content Security Policy (CSP) en todas las páginas
- ✓ Subresource Integrity (SRI) para scripts externos
- ✓ Logs de auditoría inmutables para acciones sensibles
- ✓ Monitoreo de breaches con HavelBeenPwned

KPIs de Seguridad

| Métrica                              | Umbral crítico              |
|--------------------------------------|-----------------------------|
| Decline rate de pagos                | >15% = posible card testing |
| Chargeback rate                      | >2% = indicador crítico     |
| Velocidad transacciones/IP           | >10/min = bloquear          |
| Tiempo detección de brecha (MTTD)    | Objetivo: <24h              |
| MFA adoption rate                    | Objetivo: >80%              |
| Vulnerabilidades críticas sin parche | Objetivo: 0                 |
| Score OWASP compliance               | Objetivo: >90%              |